AGE ASSURANCE HARM CARD **AA-01**

Fraud through reused age proof

DESCRIPTION

An age credential, biometric result, or verification session can be replayed, lent, or taken over, causing access or actions to be attributed to the wrong person.

QUESTIONS

1. What binds the age result to the intended person, service, session, or device?
2. Can a presentation, token, or verified account be replayed, transferred, or shared?
3. How are misuse, revocation, and incorrect attribution handled without exposing more identity data?

EXAMPLE

SCAN FOR LINKED CASE

An adult completes an age check and shares a persistent token. A minor reuses it, while the resulting account activity is attributed to the adult.

AGE ASSURANCE HARM CARD **AA-02**

Exclusion through unavailable identity evidence

Variant: Missing or unsafe evidence

DESCRIPTION

People can lose access to age-restricted or age-appropriate services when proof of age depends on legal identity or documents they cannot obtain or safely use.

QUESTIONS

1. Does proving age also require proving legal identity?
2. Which documents, issuers, or records are accepted, and who cannot obtain them?
3. What privacy-preserving alternative exists when the usual evidence is unavailable or unsafe?

EXAMPLE

SCAN FOR LINKED CASE

An undocumented adult is blocked from a lawful service because the verifier accepts only passports or national identity cards, even though the service needs only an over-18 result.

W3C Threat Modeling Community Group
https://www.w3.org/community/threat-modeling/

AGE ASSURANCE HARM CARD **AA-03**

Burden of repeated age checks

DESCRIPTION

Repeated age checks can impose recurring costs in time, fees, travel, devices, connectivity, or administrative effort on people who need access.

QUESTIONS

1. Who pays for documents, connectivity, devices, travel, or repeated verification?
2. How often must a person repeat the check across services or after an error?
3. Can repetition be reduced without creating a persistent cross-service identifier?

EXAMPLE

An adult must travel to replace a document and then pay for repeated checks on several services, turning ordinary access into a recurring cost.

SCAN FOR LINKED CASE

AGE ASSURANCE HARM CARD **AA-04**

Exclusion through unavailable identity evidence

Variant: Valid evidence not accepted

DESCRIPTION

A person can be denied access when they hold valid evidence of age, but the verifier, trust list, issuer policy, or accepted-method list does not recognize it.

QUESTIONS

1. Which issuers, credentials, documents, languages, or methods are accepted by the verifier or trust list?
2. Who has valid evidence but is excluded because the evidence is not recognized?
3. What equivalent or privacy-preserving route exists when the preferred evidence is outside the accepted list?

EXAMPLE

An adult has a valid foreign age credential, but the verifier accepts only domestic issuers and offers no equivalent route.

SCAN FOR LINKED CASE

W3C Threat Modeling Community Group
https://www.w3.org/community/threat-modeling/

AGE ASSURANCE HARM CARD **AA-05**

Persecution

DESCRIPTION

Sustained and systematic targeting of an individual with the intent of causing harm.

QUESTIONS

1. Which age-assurance records, decisions, or identifiers could make the same person repeatedly identifiable across services or over time?
2. Who can use those signals to single out or repeatedly act against that person?
3. What evidence would distinguish sustained and intentional targeting from isolated errors or ordinary enforcement?

EXAMPLE

SCAN FOR LINKED CASE

An authority repeatedly uses age-assurance logs and linked identifiers to identify the same person across services, then subjects them to repeated denials, investigations, or other adverse actions because of a disfavored status.

AGE ASSURANCE HARM CARD **AA-06**

Sensitive-attribute profiling

DESCRIPTION

Age-assurance data can be combined with other records to infer or act on ethnicity, religion, health, gender, or other sensitive characteristics unrelated to the age decision.

QUESTIONS

1. Which submitted attributes, images, device signals, or metadata can reveal sensitive characteristics?
2. Who can combine the age-assurance record with profiles held elsewhere?
3. Can an inferred characteristic change access, scrutiny, price, or enforcement?

EXAMPLE

SCAN FOR LINKED CASE

A verifier combines age-check metadata with an account profile and uses an inferred sensitive characteristic to subject some users to additional scrutiny.

W3C Threat Modeling Community Group
https://www.w3.org/community/threat-modeling/

AGE ASSURANCE HARM CARD **AA-07**

Irreplaceable biometric compromise

DESCRIPTION

When age assurance relies on face, voice, fingerprint, or other biometrics, a compromise can expose identifiers that the person cannot replace like a password.

QUESTIONS

1. Are raw biometric samples or reusable templates collected, transmitted, or retained?
2. Could another system use the exposed data for recognition, impersonation, or correlation?
3. What recovery or remedy is possible when the person cannot rotate the compromised trait?

EXAMPLE

SCAN FOR LINKED CASE

An age-estimation vendor retains selfie templates. A breach exposes data that may be reused for matching, while affected people cannot replace their faces.

W3C Threat Modeling Community Group
https://www.w3.org/community/threat-modeling/

AGE ASSURANCE HARM CARD **AA-08**

Concentrated control over access

DESCRIPTION

Centralizing age-assurance decisions in one provider, registry, or trust list gives that actor leverage over who can participate and on what terms.

QUESTIONS

1. Which provider, registry, or authority can change access for many services at once?
2. Can implementers use an interoperable alternative without excluding existing users?
3. Who reviews changes to acceptance rules, accreditation, pricing, or availability?

EXAMPLE

SCAN FOR LINKED CASE

Many services depend on one approved age-assurance provider. When it changes its document policy, the same group of users loses access across the ecosystem.

AGE ASSURANCE HARM CARD **AA-09**

False rejection of eligible users

Variant: Classification or verification error

DESCRIPTION

An incorrect underage result or failed verification can deny a person access even when the policy says they are eligible.

QUESTIONS

1. Where can an eligible person be classified as underage or fail to complete the check?
2. How do false-rejection rates vary by method, device, document, and user group?
3. What immediate fallback or review prevents the error from becoming a denial?

EXAMPLE

SCAN FOR LINKED CASE

A 19-year-old is estimated to be under 18 and blocked from a lawful service, even though the person meets the policy threshold.

AGE ASSURANCE HARM CARD **AA-10**

Exclusion from lawful economic activity

DESCRIPTION

Age-assurance requirements can block adults or young people from work, commerce, financial services, or other lawful activity when they cannot complete the check.

QUESTIONS

1. Which work, commerce, finance, or connectivity activities are gated by the age decision?
2. Is the same level of assurance necessary for every gated activity?
3. Who bears the cumulative economic loss while a failure or mismatch is resolved?

EXAMPLE

An eligible adult cannot open an account on a work platform because the assurance service does not support the person's document, so paid assignments remain inaccessible.

SCAN FOR LINKED CASE

AGE ASSURANCE HARM CARD **AA-11**

Platform and vendor power imbalance

DESCRIPTION

A wallet, operating-system vendor, or assurance provider can gain leverage over public policy and service access when implementers cannot replace it or interoperate with alternatives.

QUESTIONS

1. Which actor controls the device signal, wallet, API, trust list, or certification needed to comply?
2. Can implementers switch provider or support alternatives without rebuilding the service?
3. Who sets the terms, audits changes, and handles users excluded by a platform decision?

EXAMPLE

SCAN FOR LINKED CASE

A government specifies an age-assurance outcome, but services depend on one mobile-platform API. A platform change then determines which users and services can comply.

AGE ASSURANCE HARM CARD **AA-12**

Chilling of expression and access

DESCRIPTION

Requiring age proof or an identity-linked login can deter people from lawful speech, reading, or participation where anonymity or confidentiality matters.

QUESTIONS

1. Which lawful activities depend on anonymity, pseudonymity, or confidential access?
2. Does the service need an age result, or is it also collecting identity and activity data?
3. How will abandonment and self-censorship be observed without increasing surveillance?

EXAMPLE

SCAN FOR LINKED CASE

An adult avoids a health-support forum because access requires an identity-linked age check that could connect the visit to the person's legal identity.

AGE ASSURANCE HARM CARD **AA-13**

Overblocking and digital censorship

DESCRIPTION

Broad age-gating rules or conservative enforcement can make lawful content unavailable to adults, to minors entitled to access it, or to an entire jurisdiction.

QUESTIONS

1. Who classifies the content, selects the threshold, and decides how uncertainty is handled?
2. Could liability or enforcement incentives lead a service to block more content or users than the policy requires?
3. Can users and publishers contest a classification or blanket restriction?

EXAMPLE

SCAN FOR LINKED CASE

A platform blocks an entire information archive in one jurisdiction because it cannot reliably classify every page or user, depriving adults of lawful material.

W3C Threat Modeling Community Group
https://www.w3.org/community/threat-modeling/

AGE ASSURANCE HARM CARD **AA-14**

Loss of effective remedy

DESCRIPTION

A person harmed by an age decision can remain locked out when no actor is responsible for notice, explanation, correction, appeal, or timely restoration.

QUESTIONS

1. Which actor explains the denial: issuer, assurance provider, verifier, enforcer, or policy authority?
2. What evidence can the person see and correct without disclosing more data than the original check required?
3. What happens to access while an appeal crosses organizational boundaries?

EXAMPLE

SCAN FOR LINKED CASE

A verifier blames the assurance provider, while the provider points to the policy threshold. An eligible adult cannot correct an erroneous birth record before access is needed.

AGE ASSURANCE HARM CARD **AA-15**

Intentional exclusion through policy

DESCRIPTION

An authority or service can use age-assurance rules as a pretext to exclude a group or activity beyond the stated safety purpose.

QUESTIONS

1. Who selects the policy, assurance level, exceptions, and evidence accepted for each service?
2. Are some groups or activities subjected to stricter requirements without a purpose-related reason?
3. What audit evidence and appeal route can reveal selective or pretextual enforcement?

EXAMPLE

A service applies a higher assurance requirement only to a disfavored community's forum, blocking participants who would otherwise meet the stated age rule.

SCAN FOR LINKED CASE

W3C Threat Modeling Community Group
https://www.w3.org/community/threat-modeling/

AGE ASSURANCE HARM CARD **AA-16**

Exposure of sensitive verification data

Variant: Stored verification data

DESCRIPTION

Collecting or retaining identity-linked data for age assurance can expose people to misuse, targeting, or fraud if records are accessed beyond their intended purpose.

QUESTIONS

1. What is collected beyond the minimal age result, and where is each item stored?
2. Which issuer, verifier, intermediary, platform, or contractor can access the records?
3. How are retention, deletion, breach notice, and downstream harm handled?

EXAMPLE

SCAN FOR LINKED CASE

A central verification database stores document images, selfies, identifiers, and service history. Unauthorized access exposes both identity data and where people sought access.

AGE ASSURANCE HARM CARD **AA-17**

Exposure of sensitive verification data

Variant: Unsafe recipient or channel

DESCRIPTION

Age-assurance notifications, recovery messages, or verification status can expose sensitive information when they are delivered through a shared or unsafe device, account, address, or contact channel.

QUESTIONS

1. What verification information appears in notifications, account history, recovery messages, or support communications?
2. Who controls or can observe the destination channel?
3. Can the person suppress, redirect, or safely review a sensitive communication?

EXAMPLE

SCAN FOR LINKED CASE

An age-check failure notice is sent to a shared family account, revealing which sensitive service the person attempted to access.

AGE ASSURANCE HARM CARD **AA-18**

Sale or unauthorized secondary disclosure

DESCRIPTION

An age-assurance provider or intermediary can disclose or sell verification records to other parties, extending their use beyond the age decision and the person's reasonable expectations.

QUESTIONS

1. Which contracts and technical controls limit disclosure by providers, intermediaries, and subcontractors?
2. Can identifiers, site categories, outcomes, or device metadata be sold or shared downstream?
3. How can a person discover the disclosure and require downstream deletion or correction?

EXAMPLE

An assurance provider sells verification metadata to a data broker. The broker uses the records to profile and target people who expected only an age decision.

SCAN FOR LINKED CASE

AGE ASSURANCE HARM CARD **AA-19**

Cross-context linkability

DESCRIPTION

A persistent age credential or account requirement can make a person linkable across services, roles, or relationships that they would otherwise keep separate.

QUESTIONS

1. Does the presentation expose a stable identifier across verifiers, accounts, or devices?
2. Can the person use separate pseudonyms and prevent verifiers from correlating presentations?
3. Which actors could combine records even when each service receives only an age result?

EXAMPLE

The same stable credential identifier is presented to a gaming service and a health forum, allowing the two user profiles to be connected.

SCAN FOR LINKED CASE

W3C Threat Modeling Community Group
https://www.w3.org/community/threat-modeling/

AGE ASSURANCE HARM CARD **AA-20**

Surveillance through age checks

Variant: Service observability

DESCRIPTION

Age-assurance flows can reveal which services a person visits or what categories of content they seek to a provider, platform, or authority that does not need that information.

QUESTIONS

1. At which network, wallet, issuer, status, callback, or logging point can service use be observed?
2. Does any actor receive activity reports or correlate checks across sites and time?
3. Can the age result be delivered without revealing the verifier or later use to the assurance party?

EXAMPLE

SCAN FOR LINKED CASE

A central provider receives a callback for every age-gated site a person visits and retains the events, creating a history of sensitive activity.

AGE ASSURANCE HARM CARD **AA-21**

Surveillance through age checks

Variant: State correlation

DESCRIPTION

Age-assurance records can be combined with identity, benefits, transaction, or other government records, allowing an authority to monitor a person's activity across otherwise separate services.

QUESTIONS

1. Which actors can combine age-check records with identity, benefit, transaction, or service-use data?
2. Can repeated checks reveal where, when, or why a person accesses different services?
3. What technical or governance boundary prevents an age-assurance record from becoming a general monitoring signal?

EXAMPLE

SCAN FOR LINKED CASE

An authority links age-assurance events with a national identity and benefits database, creating a record of which age-gated services the same person accesses.

AGE ASSURANCE HARM CARD **AA-22**

Surveillance through age checks

Variant: Biometric surveillance

DESCRIPTION

Biometric data captured for age estimation can be retained or repurposed for recognition, identification, or tracking beyond the original age decision.

QUESTIONS

1. Are images, biometric features, or reusable templates retained after the age decision?
2. Who can compare them against other biometric or identity datasets?
3. Can age estimation be performed without creating an artifact usable for later recognition?

EXAMPLE

Selfies collected to estimate age are later matched against another facial-recognition system, allowing users to be identified or tracked outside the original service.

SCAN FOR LINKED CASE

AGE ASSURANCE HARM CARD **AA-23**

Loss of pseudonymity and contextual identities

DESCRIPTION

Using legal identity or one verified account for every age-gated service can prevent people from keeping pseudonyms and social contexts separate.

QUESTIONS

1. Does the service require legal identity when it needs only an age threshold?
2. Can a person maintain different pseudonyms without those accounts becoming linkable?
3. What happens when one verified identity becomes the key to participation across many contexts?

EXAMPLE

SCAN FOR LINKED CASE

An artist, gamer, and support-group participant must use one verified account for all three roles, making previously separate communities linkable.

AGE ASSURANCE HARM CARD **AA-24**

Function creep

Variant: Monitoring and enforcement

DESCRIPTION

An age signal, identifier, or supporting record collected to make an access decision can later be reused for monitoring, policing, or enforcement unrelated to age.

QUESTIONS

1. What purpose justified collecting the data in the first place?
2. Which authorities or other recipients could later obtain or query it?
3. What prevents an age-assurance identifier or log from being reused for unrelated enforcement?

EXAMPLE

SCAN FOR LINKED CASE

An identifier introduced only to support age checks is later combined with service-use logs to identify people for an unrelated enforcement activity.

AGE ASSURANCE HARM CARD **AA-25**

Function creep

Variant: Commercial profiling

DESCRIPTION

An age signal, credential, or supporting data collected for one access decision can later be reused for profiling, advertising, eligibility, policing, or other unrelated decisions.

QUESTIONS

1. What purpose justified the original age check, and which later uses are technically possible?
2. Who can authorize a new use, and can the person refuse it without losing the original service?
3. Which protocol, retention, and governance choices prevent the identifier or result from becoming general-purpose?

EXAMPLE

A platform begins with an over-18 check, then reuses the credential identifier to profile the same accounts across services for advertising.

SCAN FOR LINKED CASE

AGE ASSURANCE HARM CARD **AA-26**

Function creep

Variant: Biometric secondary use

DESCRIPTION

Biometric samples or derived templates collected to estimate age can become reusable identity data and later support decisions or purposes unrelated to age assurance.

QUESTIONS

1. Which biometric artifacts remain after the age estimate is produced?
2. Can they later be used for identification, authentication, matching, or another decision?
3. Who can authorize that new purpose, and can the person meaningfully refuse it?

EXAMPLE

SCAN FOR LINKED CASE

A face template originally generated only for age estimation is later added to an identity-matching system and used for purposes unrelated to the original access decision.

AGE ASSURANCE HARM CARD **AA-27**

Digital divide

DESCRIPTION

Age-assurance systems can create unequal access when they assume current documents, personal devices, reliable connectivity, private accounts, or high digital literacy.

QUESTIONS

1. Does the flow work on older devices, low bandwidth, shared devices, and assisted or offline channels?
2. Who lacks the document, account, language, accessibility support, or private space the method assumes?
3. Does the fallback preserve dignity and privacy, or impose a higher burden?

EXAMPLE

SCAN FOR LINKED CASE

An eligible adult uses a shared basic phone and cannot complete an app-to-wallet selfie handoff, so the service remains inaccessible.

AGE ASSURANCE HARM CARD **AA-28**

False rejection of eligible users

Variant: Registry or trust-list unavailable

DESCRIPTION

An eligible person can be denied when the verifier cannot reach the registry, status service, or allowlist needed to validate otherwise valid age evidence.

QUESTIONS

1. Which registry, status endpoint, provider, or network dependency is required at access time?
2. What does the verifier do when the dependency is unavailable or returns stale information?
3. Can cached proofs, another provider, or a non-digital path preserve access during an outage?

EXAMPLE

SCAN FOR LINKED CASE

A credential-status endpoint is unavailable, so relying services reject every age proof and eligible adults are locked out until the dependency recovers.

AGE ASSURANCE HARM CARD **AA-29**

Credential suspension disrupts digital access

DESCRIPTION

People can lose time-sensitive access when a credential is suspended, revoked, expired, or left in a stale state even though their underlying identity or eligibility has not changed.

QUESTIONS

1. What can suspend, revoke, expire, or invalidate the credential?
2. Which services fail before the holder can update or replace it?
3. How does the person learn what happened and complete recovery?
4. What fallback preserves access for people without another credential, supported device, or nearby service point?

EXAMPLE

SCAN FOR LINKED CASE

A national digital identity or digital credential is suspended after a security issue. Services that depend on it reject holders until the credential is restored or replaced, even though their underlying identity or eligibility has not changed.

W3C Threat Modeling Community Group
https://www.w3.org/community/threat-modeling/

AGE ASSURANCE HARM CARD **AA-30**

Forced association

DESCRIPTION

Required enrollment and participation in the digital identity system.

QUESTIONS

1. Does access require enrolling in or using a particular digital identity system even when the service needs only an age threshold?
2. Can a person prove age without creating or linking a persistent identity or account?
3. What access, privacy, or autonomy loss follows for people who cannot or do not want to enroll?

EXAMPLE

SCAN FOR LINKED CASE

A service requires every adult to enroll in a national digital identity system and use an identified account to prove they are over 18, even though a non-identifying age signal would be sufficient.